

Лекция 12. Угрозы безопасности информации на прикладном уровне модели OSI

Учебные вопросы:

1. Система доменных имен BIND (DNS).
2. Веб-сервер Apache.
3. Системы контроля версий.
4. Агенты передачи сообщений.
5. Защита работающих служб

В данной лекции рассматриваются базовые угрозы, которые могут затронуть уровни 5, 6 и 7 модели OSI, соответствующие прикладному уровню TCP/IP. Существует множество приложений, которые уязвимы для эксплойтов. У большинства из них могут быть проблемы на всех трёх верхних уровнях модели OSI.

1. Система доменных имен BIND (DNS)

BIND (Berkley Internet Name Domain) - наиболее часто используемый DNS-сервер в Интернете. В настоящее время в каждом дистрибутиве Linux есть пакет BIND для служб DNS.



Рис. 1 Система доменных имен

Проблема с BIND и любым DNS-сервером заключается в том, что для того, чтобы иметь возможность преобразовывать имена в IP-

адреса, он должен взаимодействовать со множеством других DNS-серверов, поэтому фильтрация DNS-пакетов невозможна.



Службы DNS жизненно важны для работы в Интернет. Поэтому, чтобы нарушить процесс обслуживания жертв, злоумышленники очень заинтересованы в отключении DNS-серверов. Хотя BIND хорошо известен своими проблемами безопасности (которые можно исправить), существует ещё множество

уязвимых серверов BIND, поэтому нужно быть очень осторожным при работе с BIND.

Опрос DNS-серверов на <http://mydns.bboy.net/survey> демонстрирует популярность BIND:

Number of domains serviced by each program		
70.105%	24,335,752	BIND
15.571%	5,405,266	TinyDNS
6.237%	2,165,143	Microsoft DNS Server
2.792%	969,097	MyDNS
1.964%	681,614	PowerDNS
1.250%	433,905	Simple DNS Plus
1.138%	395,206	Unknown
0.277%	96,232	Plaint DNS Server
0.203%	70,455	NSD
0.144%	49,921	UltraDNS
0.104%	36,195	Net::DNS::Nameserver
0.083%	28,656	QuickDNS
0.064%	22,087	Incognito DNS Commander
0.025%	8,508	MaraDNS
0.024%	8,174	rbldnsd
0.018%	6,135	Totd
0.001%	386	ATLAS
0.001%	371	Posadis
0.001%	312	NonSequitur DNS
0.000%	12	Nominum ANS/CNS

Рис. 2 Статистические данные

Советы о том, как можно обеспечить безопасность BIND:

~ не используйте пакет BIND, поставляемый с вашим дистрибутивом Linux; загрузите последнюю версию с веб-сайта BIND (<http://www.isc.org>);

~ поместите BIND в chroot-jail. Это лучшее, что можно сделать для защиты от удаленно эксплуатируемых уязвимостей в BIND. Если вы не выполните chroot для своей версии BIND и такая уязвимость будет обнаружена, ваш Linux-сервер и все данные на нем могут быть скомпрометированы до того, как вы успеете выполнить обновление.

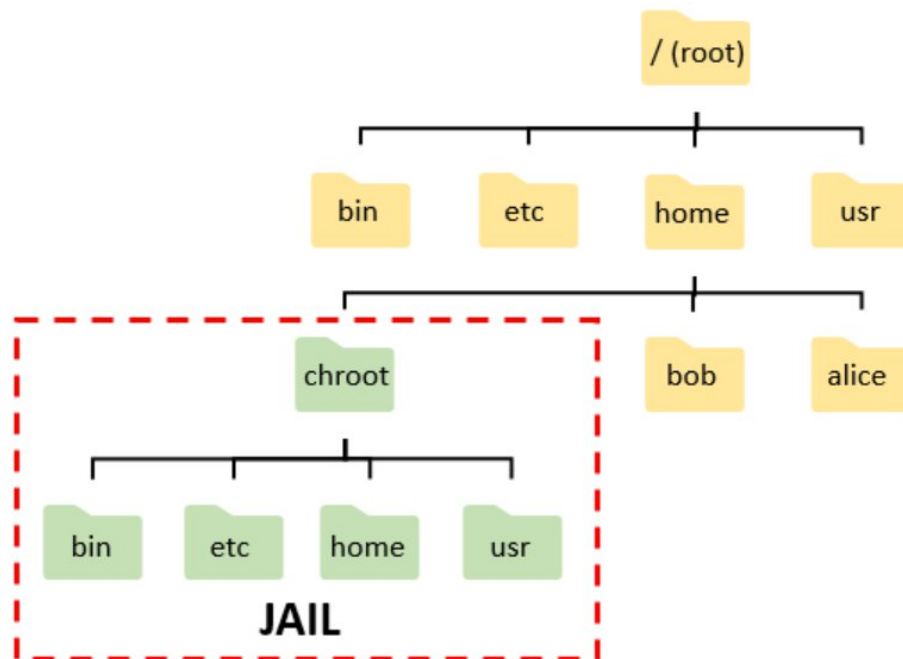


Рис. 3 Chroot-JAIL

~ всегда применяйте исправления и обновляйте BIND всякий раз, когда обнаруживается ошибка или выходит новая версия;

~ обезопасьте зону между первичным и вторичным DNS-серверами с использованием подписей транзакций DNS (TSIG);

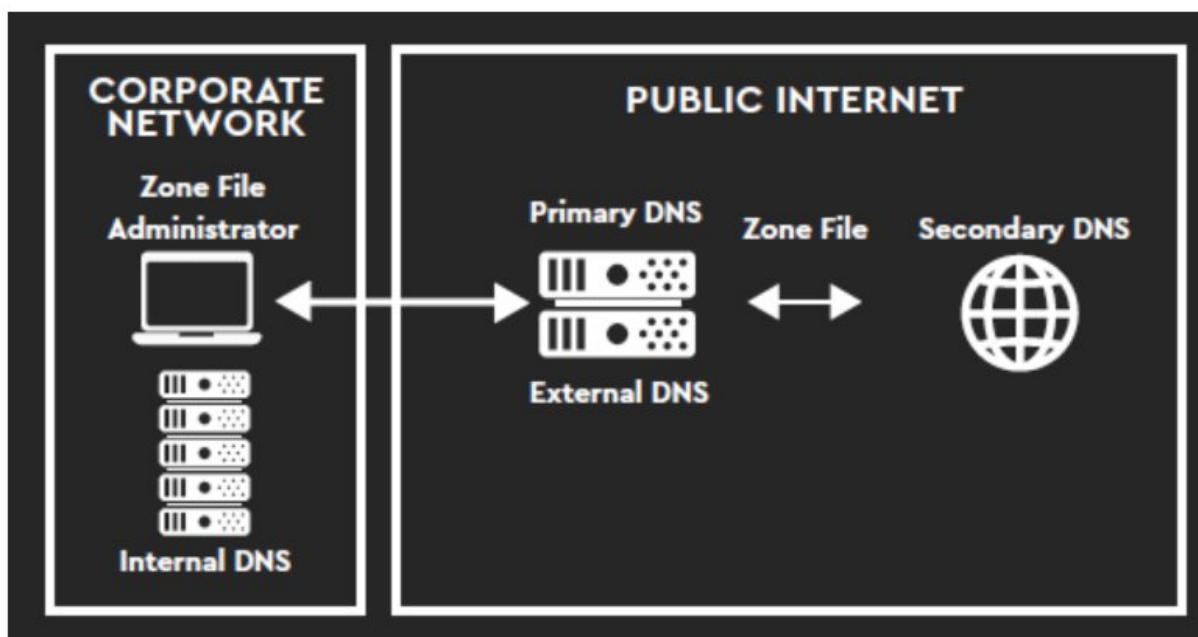


Рис. 4 Зона первичного и вторичного DNS-сервера
~ отключите рекурсию;

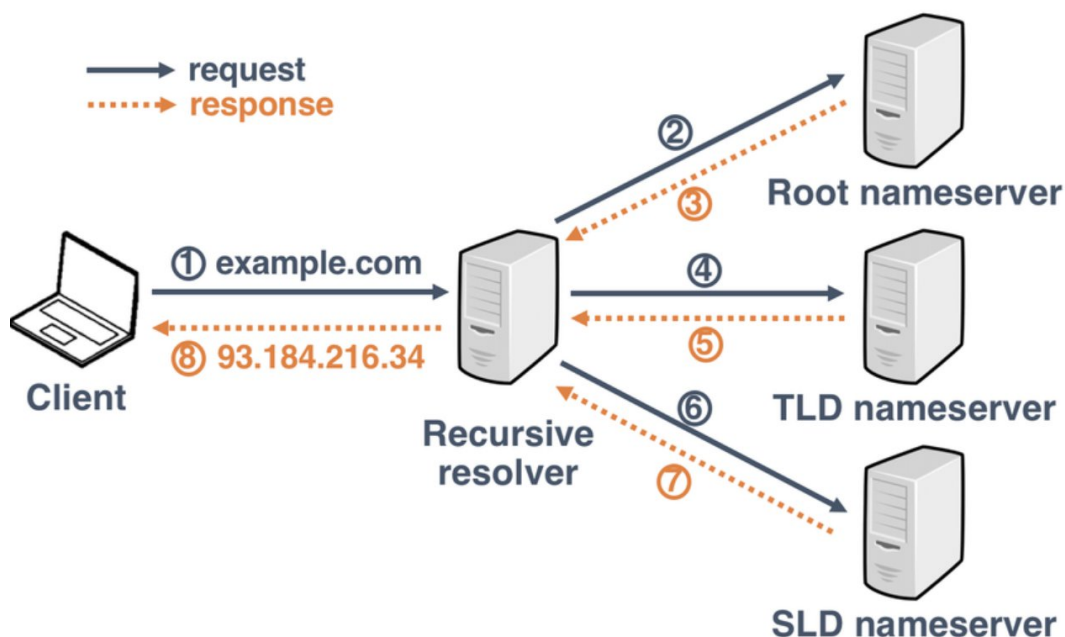


Рис. 5 Процесс, при котором сервер выполняет полный поиск нужной информации во всей системе DNS, при необходимости обращаясь к другим DNS-серверам.

Хотя BIND более популярен и его проще настроить, рассмотрите возможность использования, ну например, TinyDNS, как более безопасный.

2. Веб-сервер Apache

Самым популярным веб-сервером является Apache (<http://www.apache.org>), у которого в прошлом были некоторые проблемы с безопасностью.

Ниже приведены некоторые советы как повысить безопасность сервера Apache:

- ~ «пропатчите» свой сервер и постарайтесь поддерживать его в актуальном состоянии, насколько это возможно;

- ~ удалите все примеры скриптов дополнительных модулей (mod_php, mod_cgi, mod_perl и т.д.).

- ~ если вы работаете с PHP, CGI и другими языками сценариев, рассмотрите возможность использования suEXEC, программы-оболочки, вызываемой Apache, чтобы позволить ему вызывать сценарии с другим идентификатором пользователя, отличный от того, который используется для Apache;

- ~ не разрешайте загрузку каких-либо скриптов на ваш веб-сервер ненадежными/не доверенными сторонами;

- ~ не запускайте веб-сервер как root. Создайте пользователя с минимальными правами для запуска веб-сервера;

- ~ измените токен ответа для вашего веб-сервера. Злоумышленнику труднее вывести его из строя, если он или она не знает, на каком веб-сервере вы работаете.



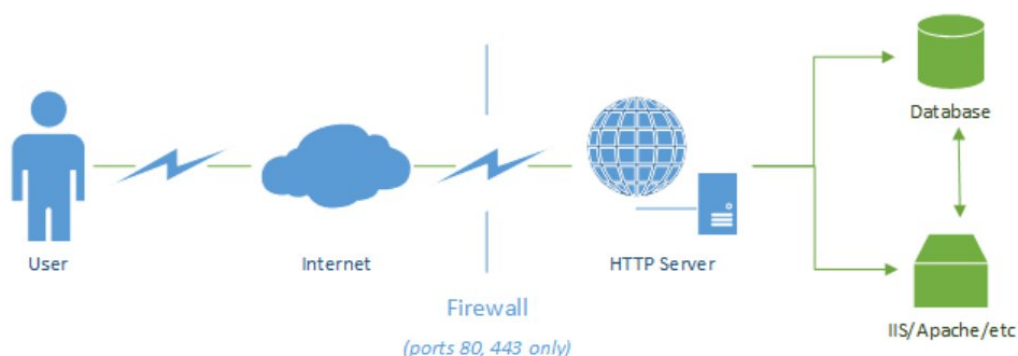


Рис. 6 Типичная схема защиты сервера Apache

3. Системы контроля версий

Системы контроля версий предоставляют разработчикам программного обеспечения инструменты для одновременной работы с одним и тем же набором файлов и управления разными версиями исходного кода.

CVS

В системах Linux самой популярной системой контроля версий когда-то была **CVS** (Concurrent Versions System), используемая многими проектами программного обеспечения с открытым исходным кодом, которые разрешают анонимный доступ к своим репозиториям CVS через протокол pserver, который по умолчанию работает на TCP-порту 2401.

Сервер CVS с удалённым доступом имеет следующие уязвимости:

- ~ переполнение буфера кучи, которое может быть вызвано специально созданными строками ввода. Код эксплойта для серверов CVS был опубликован в списках безопасности и позволяет злоумышленникам выполнять произвольный код на сервере CVS;

- ~ имеются некоторые уязвимости в реализации других команд и функций, которые могут быть использованы аутентифицированным пользователем для вызова отказа в обслуживании или выполнения

произвольного кода на сервере CVS. Некоторые из них могут быть использованы анонимными пользователями.

Чтобы защититься от этих уязвимостей:

- ~ обновите CVS до последней стабильной версии;
- ~ запустите сервер CVS в chroot-окружении (chroot jail);
- ~ настройте CVS для использования протокола SSH вместо протокола rserver (который отправляет пароли в открытом виде);
- ~ если вы не разрешаете анонимный доступ к вашему серверу CVS, попробуйте отфильтровать порт 2401, чтобы к нему могли подключаться только доверенные хосты;
- ~ разместите сервер CVS для анонимного доступа только для чтения в автономной системе (stand-alone);
- ~ Запустите на проверку все опубликованные эксплойты против ваших серверов CVS.

Subversion

Ещё одна система контроля версий, которая приобрела популярность в Linux - это **subversion**. Доступ к репозиторию Subversion можно получить удаленно по протоколу svn. Сервер svn по умолчанию работает на TCP-порту 3690 и содержит следующие уязвимости:

- ~ переполнение буфера кучи, которое может быть использовано злоумышленниками, не прошедшими проверку подлинности, для выполнения произвольного кода на сервере;
- ~ переполнение буфера стека, которое может быть вызвано специально созданной командой `get-date-rev svn`. Таким же образом злоумышленник, не прошедший проверку подлинности, может выполнить произвольный код. Для этой уязвимости в списках безопасности было опубликовано несколько эксплойтов.

Чтобы защитить свой сервер Subversion от этих уязвимостей:

- ~ обновите программное обеспечение Subversion до последней стабильной версии;
- ~ настройте subversion для использования webDAV вместо протокола svn;
- ~ если вы не разрешаете анонимный доступ к вашему серверу Subversion, попробуйте отфильтровать TCP-порт 3690, чтобы разрешить только доверенные хосты;
- ~ запустите опубликованные эксплойты против вашего сервера Subversion;
- ~ разместите сервер subversion для анонимного доступа только для чтения на автономной системе (stand-alone).

4. Агенты передачи сообщений



(MTA - Mail Transport Agents)

Электронная почта - один из самых популярных сервисов в Интернете, и для компании это жизненно важный сервис практически в каждом отделе.

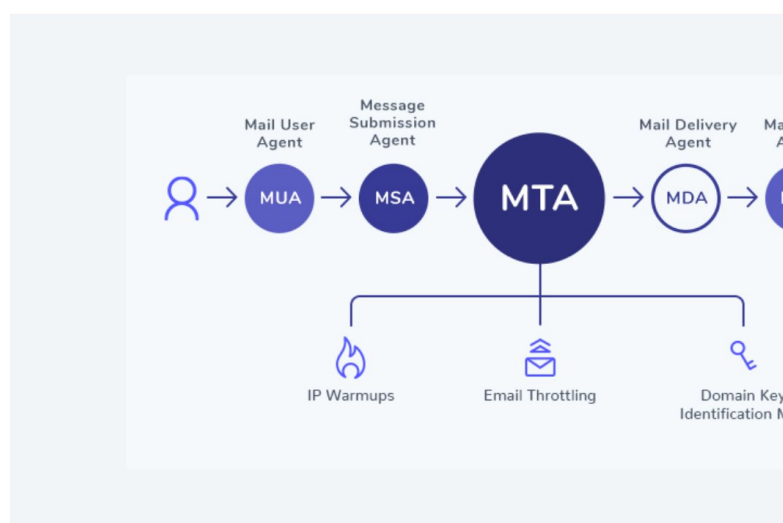


Рис. 7 Агенты передачи сообщений

SMTP (Send Mail Transport Protocol) - один из старейших протоколов в Интернете, который используется MTA для отправки

электронной почты от отправителя получателем. SMTP прослушивает TCP-порт 25 по умолчанию, и, если он используется для получения электронной почты с любого адреса электронной почты в Интернете, его нельзя фильтровать.

Самым популярным MTA для Linux когда-то был Sendmail, у которого было много проблем с безопасностью, включая переполнение буфера, которое можно было удаленно использовать для компрометации сервера MTA.

Альтернативами Sendmail являются Postfix, Qmail, Exim и Courier-MTA.

Наиболее популярными проблемами MTA являются:

- ~ уязвимости, такие как переполнение буфера, переполнение кучи и т. д., которые могут быть использованы удаленными или локальными злоумышленниками для компрометации сервера, на котором работает MTA;

- ~ неправильная конфигурация MTA, позволяющая всем использовать его для отправки почты. Это называется открытой ретрансляцией. Неправильно настроенные MTA как открытые ретрансляторы немедленно попадают в руки спамеров, которые могут нанести большой ущерб вашей компании, поскольку ваш почтовый сервер попадёт в один из многочисленных чёрных списков почтовых серверов, плюс ко всему спам потребляет вашу пропускную способность;

- ~ уязвимости раскрытия базы данных учетных записей пользователей.

Протокол управления сетью SNMP

В наши дни большинство сетевых устройств используют SNMP для удаленного мониторинга и настройки.

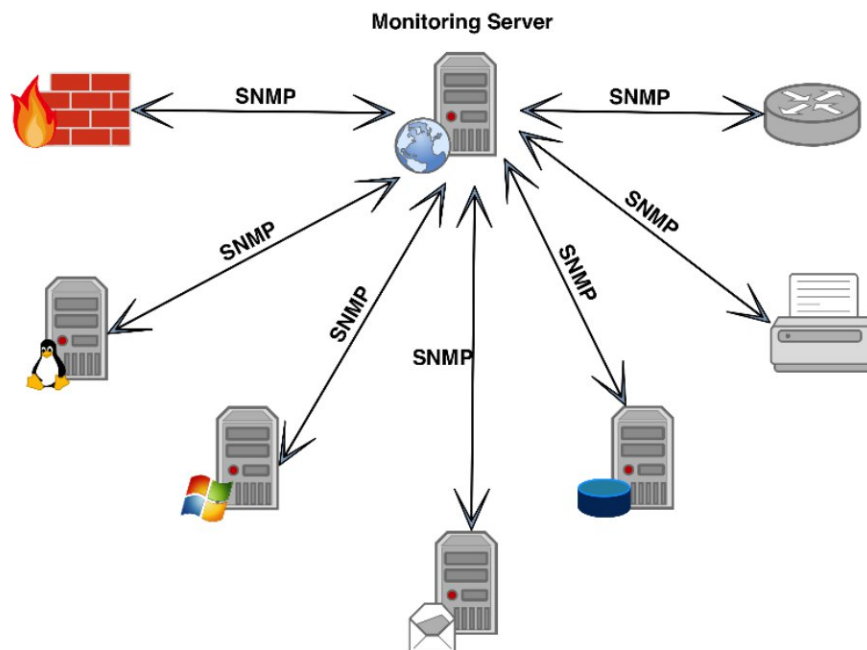


Рис. 8 SNMP протоколы

SNMP — это простой протокол, обычно используемый для создания программного обеспечения для мониторинга, которое может получать такую информацию, как сетевой трафик, загрузка ЦП, загрузка диска и т. д., а также изменять конфигурацию устройств, таких как беспроводное оборудование, маршрутизаторы и т. д.

В большинстве реализаций SNMP на таких сетевых устройствах используется версия 1 или версия 2, которые имеют очень слабый метод аутентификации. SNMP версии 1 содержит ряд ошибок в способах обработки и декодирования сообщений ловушек и запросов SNMP, которые можно использовать разными способами, от отказа в обслуживании до перезаписи конфигурации.

Версии 1 и 2 SNMP используют строки сообщества (community string) для аутентификации. Они отправляются через UDP-порт 161 в незашифрованном виде. Когда вы настраиваете SNMP на устройстве (включая систему Linux), вы должны настроить две строки сообщества: одну с доступом только для чтения и по умолчанию общедоступную (public), а другую с доступом для чтения и записи и по умолчанию

частную (private). Если этого не сделать, при отсутствии межсетевого экрана очень легко просмотреть их конфигурацию и изменить её.

Это очень опасно для устройств и сети.

Итак, вот что вы должны попробовать сделать:

- ~ старайтесь не использовать SNMP, если в этом нет необходимости;
- ~ по возможности используйте SNMP версии 3, которая имеет аутентификацию в пользовательском режиме и может выполнять шифрование;
- ~ в любом случае, если вы используете SNMP, измените сообщества по умолчанию (default communities);
- ~ настройте межсетевой экран на устройстве или на устройстве перед ним, разрешая только доверенным узлам подключаться с использованием SNMP.

Например, маршрутизатор Cisco, использующий SNMP со строкой сообщества «public», раскрывает всю свою текущую конфигурацию, включая имена пользователей и пароли. Если маршрутизатор имеет «частное» сообщество SNMP для записи, вы можете изменить абсолютно всё в конфигурации. Более того, на большинстве маршрутизаторов Cisco SNMP включен по умолчанию с сообществами по умолчанию и без фильтров.

OpenSSL

Библиотека OpenSSL является наиболее популярным выбором для приложений, которым требуется криптографическая поддержка в сетевых соединениях. К таким приложениям относятся Apache (защищённые соединения HTTP), Sendmail, OpenLDAP, OpenSSH и т.д.

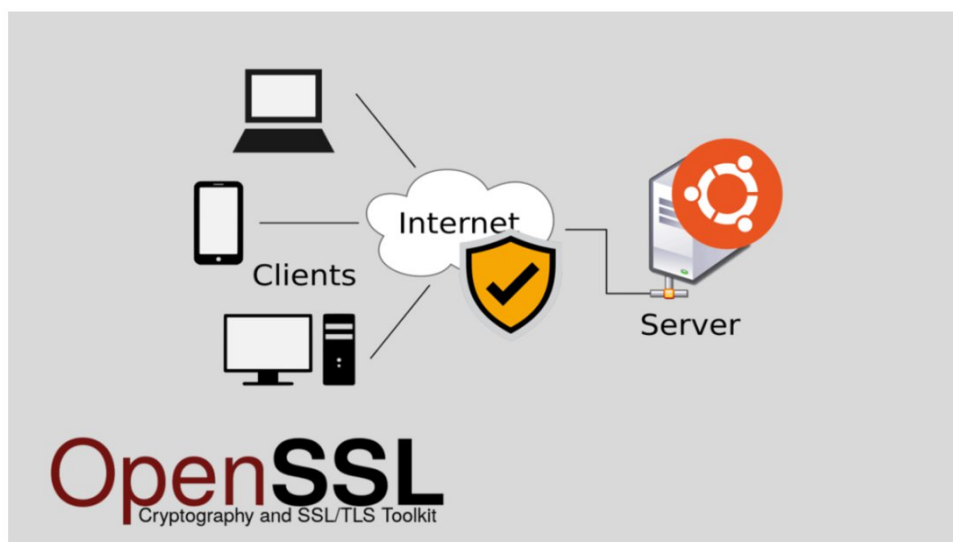


Рис. 9 OpenSSL

Уязвимости в одной версии библиотек OpenSSL затрагивают все приложения, которые их используют, и могут быть использованы через них.

В зависимости от функций, используемых приложением, уязвимости в OpenSSL могут быть использованы через приложение для выполнения произвольного кода на сервере или даже для получения привилегий root.

В прошлом у OpenSSL были некоторые уязвимости, которые наносили большой ущерб серверам, на которых работали приложения, скомпилированные с поддержкой OpenSSL, особенно Apache, Sendmail и OpenSSH. В случае с Sendmail в списках рассылки безопасности был опубликован эксплойт, дающий злоумышленнику привилегии суперпользователя.

Чтобы оставаться защищённым, примите во внимание следующее:

- определите версию OpenSSL на каждом из серверов, на которых установлены библиотеки. Проверьте, установлена ли у вас последняя версия и есть ли в вашей версии OpenSSL уязвимости, которые можно использовать удаленно;
- обновите свою библиотеку OpenSSL до последней версии;

- ~ определите приложения, использующие библиотеку OpenSSL, и, если они требуют перекомпиляции из-за обновления, перекомпилируйте их для использования новых библиотек;

- ~ если приложения, использующие OpenSSL, не требуют подключений от всех, настройте межсетевой экран, чтобы разрешать подключения только с надежных сайтов.

5. Защита работающих служб

Работа сетевого администратора заключается в обеспечении работоспособности и безопасности сети. Есть службы, которые от него не зависят; например, веб-сервер может управляться веб-мастером.

Для усиления безопасности:

- ~ определите службы, которые работают в системе. Самое главное, определите открытые порты и службы, которые их открыли;

- ~ проверьте текущую версию каждой запущенной службы. Обновите до последней версии. Ищите уязвимости сервиса на его домашней странице;

- ~ проверьте конфигурации и, если возможно, создайте программные списки доступа, чтобы разрешить использование этой службы только доверенным хостам. Попробуйте каждый раз менять имена пользователей и пароли по умолчанию. Если вы можете запустить программу в chroot-окружении, сделайте это;

- ~ если служба не требует доступа отовсюду, настройте межсетевой экран, чтобы ограничить доступ только доверенными узлами;

- ~ проведите аудит своей сети. Попробуйте взломать вашу сеть. Подключитесь к своей сети как посторонний и проверьте все запущенные службы на наличие известных эксплойтов. Ищите хакерские инструменты и используйте их против своей собственной сети, чтобы увидеть, что произойдет;

~ создайте журналы для запросов аутентификации. Также попробуйте запустить систему обнаружения сетевых вторжений, такую как Snort.

Не все шаги требуются для каждой службы, работающей в вашей сети. Например, есть некоторые сервисы, для которых вы разрешаете подключения только с локального хоста и всё.